

Criptografía

Tabla de contenidos

Introducción	1
Codificación de mensajes	2
Criptosistemas de clave privada	3
Criptosistemas de clave pública	4
Cifrado RSA	6
Retos actuales	7

Introducción

<https://www.youtube.com/embed/Q8K311s7EiM?end=117>

La criptografía es un conjunto de técnicas matemáticas que estudian aspectos relacionados con la **seguridad de la información** transmitida a través de un cierto canal; tales como:

- **Confidencialidad:** habilidad de restringir la información únicamente a los agentes autorizados.
- **Integridad de los datos:** habilidad de proteger la información contra todo tipo de alteraciones no autorizadas (inserción, borrado, sustitución o manipulación).
- **Autenticación:** referida a los agentes, es la habilidad de identificarse inequívocamente; referida a la información, la habilidad de certificar el origen.
- **No repudio:** habilidad de Alice de enseñar a Bob una prueba de que ciertos datos provienen de Alice, de forma que Bob no solo quede convencido sino que además pueda convencer a terceras partes (Charlie), incluso si Charlie no confía en Bob.

Ahora vamos a fijar los nombres de algunos elementos de la comunicación confidencial.

1. **Entidad:** toda persona o agente que puede usar un canal para mandar, recibir o manipular información (persona, institución, terminal...). Habitualmente reciben el nombre de *Alice* y *Bob*.
2. **Emisor:** entidad transmisora legítima de la información (*Alice*).

3. **Receptor:** entidad que legítimamente debe tener acceso a la información (*Bob*).
4. **Adversario:** cualquier entidad con acceso a parte o a la totalidad de la información transmitida y que no es el emisor ni el receptor (*Eve*, si se limita a acceder; *Mallory*, si además es maliciosa).
5. **Canal:** medio físico de transmisión. Los canales pueden ser inseguros (es posible escribir, reordenar, borrar o insertar) o seguros (por medios físicos o criptográficos).

El problema clásico de la confidencialidad criptográfica es el siguiente: tenemos dos agentes, denotados **A** (*Alice*) y **B** (*Bob*), que quieren establecer una comunicación confidencial por un canal inseguro, y un tercer agente, **E** (*Eve*), que tiene la capacidad de interceptar y leer (pero no modificar) los mensajes que se intercambian por este canal.

Si Bob quiere enviar un mensaje a Alice, y desea que sea confidencial, cifra ese mensaje con una **función de cifrado** C y lo transmite por el canal. Cuando Alice lo recibe, aplica una **función de descifrado** D para recuperar el mensaje original. Aunque Eve ha podido interceptar el mensaje, un buen protocolo criptográfico hace prácticamente imposible que pueda descifrarlo sin una clave particular.

Codificación de mensajes

<https://www.youtube.com/embed/Q8K311s7EiM?start=117&end=185>

Para muchos criptosistemas supondremos que los mensajes que Alice y Bob quieren intercambiar son **números enteros** en una base previamente acordada (típicamente 2), y conocida por todos los agentes, o bien una **congruencia** módulo un cierto entero N , también conocido por todos, incluida Eve. Eventualmente, necesitaremos mensajes más complicados y consideraremos vectores de enteros o congruencias.

La forma más simple de asignar enteros a un mensaje es considerar el **alfabeto de las mayúsculas** (quizá con el espacio en blanco, aunque no es usual), y asignar a cada letra su número, empezando por 0. Esto es, identificando cada letra con un entero módulo 26:

$$A \rightarrow 0, B \rightarrow 1, \dots, Y \rightarrow 24, Z \rightarrow 25.$$

O en español, en $\mathbb{Z}/27\mathbb{Z}$:

$$A \rightarrow 0, B \rightarrow 1, \dots, \tilde{N} \rightarrow 14, \dots, Z \rightarrow 26.$$

Ahora un mensaje no es más que un elemento de $(\mathbb{Z}/N\mathbb{Z})^r$, donde N y r varían en cada criptosistema.

Típicamente, los criptosistemas más modernos operan sobre enteros o congruencias modulares **muy grandes**, del orden de 2^{2048} o 2^{4096} ; esto es, enteros de entre **600 y 1300** cifras decimales

aproximadamente. Por tanto, necesitamos una forma de convertir mensajes de texto en enteros. No solo eso: algunos mensajes muy largos habrá que **partirlos en bloques** del tamaño adecuado antes de aplicar el criptosistema; y en otros casos habrá que **alargar** los mensajes excesivamente cortos hasta un tamaño suficiente; a esta técnica se le conoce como **padding** y, si se realiza de forma incorrecta, puede ser una debilidad del criptosistema.

Una forma de asignar un entero a un mensaje es usar la **tabla de caracteres** para enumerar mensajes: cada carácter de un mensaje se sustituye por su código binario de uno o más bytes, los bytes se componen uno a continuación de otro, y el entero decimal resultante es el mensaje.

Criptosistemas de clave privada

<https://www.youtube.com/embed/Q8K31ls7EiM?start=185&end=350>

Entendemos por **criptosistemas de clave privada** aquellos en los que solo Alice y Bob conocen una clave secreta k que suponemos han intercambiado de forma segura y Eve no la conoce.

Además, suponemos:

- Alice dispone de una aplicación (conocida) de cifrado $C(\cdot, \cdot)$ y puede calcular en tiempo polinomial $C(k, m) = M$.
- Bob dispone de una aplicación (conocida) de descifrado $D(\cdot, \cdot)$ y puede calcular en tiempo polinomial $D(k, M) = m$.
- Eve conoce $C(\cdot, \cdot)$, $D(\cdot, \cdot)$ y M , pero sin conocer k no puede calcular m . En términos prácticos, esto quiere decir que sin conocer k , el algoritmo para calcular m es al menos (sub)exponencial.

Estos criptosistemas fueron los usados hasta la Segunda Guerra Mundial; con la llegada de los ordenadores, la seguridad se vio comprometida porque con **ataques de fuerza bruta** se consigue descifrar el mensaje sin conocer k . Veremos algunos ejemplos de criptosistemas clásicos terminando con **Enigma**, que fue el último en ser usado en el ámbito militar, donde vivían las comunicaciones seguras en la era pre-digital.

Actualmente, se utilizan algunos como **AES**, **DES**, **RC4**... Aunque como veremos la clave privada tiene un uso más exclusivo en la actualidad que la clave pública, hemos de entender que ambas conviven dependiendo de nuestras necesidades.

Definición

Un sistema criptográfico de clave privada es un par de funciones

$$C : \mathcal{K} \times \mathcal{P} \rightarrow \mathcal{C}, \quad D : \mathcal{K} \times \mathcal{C} \rightarrow \mathcal{P},$$

donde $\mathcal{K}$ es el conjunto de claves posibles, $\mathcal{P}$ el conjunto de mensajes en claro posibles,

y $\mathcal{C}$ el conjunto de mensajes cifrados posibles, tales que para todo $k \in \mathcal{K}$ y todo $m \in \mathcal{P}$, si ponemos $C(k, m) = M$, entonces $D(k, M) = m$; es decir,

$$C(k, D(k, m)) = m.$$

Se podría razonar que supone una pérdida innecesaria de seguridad que Eve conozca C y D . A priori puede parecer más seguro que Eve no sepa cómo se cifra y descifra, pero en la práctica no es así: muchos sistemas criptográficos han basado su seguridad en la **opacidad** del cifrado y, cuando éste ha sido desvelado (y, tarde o temprano, sucede), todo el sistema se ha visto comprometido. Una postura de cifrado **abierto**, donde todo el mundo es retado a derrotar al sistema, garantiza mucha más fiabilidad.

Formalmente, estas son solo parte de las exigencias que debe cumplir un sistema. En la vida real, la implantación de un sistema criptográfico nunca es un problema teórico puro: hay que evaluar criterios prácticos tales como **nivel de seguridad, funcionalidad, método de operación, eficiencia y facilidad de implementación**.

En el siglo XIX, el criptógrafo **Auguste Kerckhoffs** estableció seis principios para el diseño de cifrados militares:

1. Deben ser irrompibles en la práctica o incluso teóricamente.
2. Su seguridad no debe depender de los datos del criptosistema, únicamente del desconocimiento de la clave.
3. Sus claves deben ser fáciles de recordar y de cambiar.
4. Se deben poder aplicar a comunicaciones telegráficas.
5. Deben ser portables y operados fácilmente por una sola persona.
6. Deben ser fáciles de usar.

Criptosistemas de clave pública

A principios de los 70 nació un concepto que revolucionó completamente la criptografía moderna: la **clave pública**. Los primeros en plantearlo fueron **Diffie y Hellman**, motivados por el enorme desarrollo de las comunicaciones y tecnologías de la información desde los años 60, que llevó la criptografía más allá del ámbito militar hacia el **mundo comercial**.

El problema al que se enfrentaron Diffie y Hellman era el **intercambio de claves** en sistemas de clave privada: con el aumento exponencial de mensajes y usuarios, las claves bien usadas tienen una vida útil y se necesita un sistema **flexible y sencillo** de intercambio que se pueda usar con frecuencia.

En un protocolo formal de clave pública, la idea fundamental es abandonar conceptos tradicionales:

- Dejamos de pensar en dos usuarios: pensamos en una **comunidad** de usuarios (Alice, Bob y, por qué no, Eve).
- Dejamos de pensar que la clave de cifrado y la clave de descifrado son esencialmente lo mismo; en su lugar tenemos una **función trampa** (*trapdoor*): conociendo la clave de cifrado es sencillo averiguar la de descifrado, pero el camino inverso no es factible computacionalmente.
- Dejamos de pensar en cifrar para que solo emisor y receptor puedan descifrar: ciframos de forma que **solo el destinatario** pueda descifrar.

Así, Alice tiene una **clave pública** K_A que todo el mundo conoce (en la vida real se publican en listados). Bob tiene la suya K_B (Eve también, como usuaria). Lo importante es que K_A viene acompañada de una **clave privada** k_A (para descifrar). Teóricamente k_A se podría hallar a partir de K_A , pero en la práctica no es posible: solo Alice conoce k_A (análogamente, solo Bob conoce k_B).

https://www.youtube.com/watch?v=U2OLu_Col0o

Tenemos una función de **cifrado pública** que depende de dos parámetros: la clave de cifrado pública y el mensaje a cifrar. Tenemos también una función de **descifrado** que verifica dos condiciones:

- El cálculo del descifrado conociendo la **clave privada** es rápido.
- El cálculo del descifrado **sin** conocer la clave privada es demasiado lento.

Si Alice quiere enviar un mensaje m a Bob, realiza el cálculo de cifrar con la **clave pública de Bob** y obtiene el mensaje cifrado M . Este mensaje ni siquiera la propia Alice podría descifrarlo (no lo necesita porque tiene el texto en claro). Envía M y entonces Eve, si quiere recuperar m , debe descifrar M **sin** conocer k_B , mientras que Bob puede realizar este cálculo sin problema.

Por tanto, la idea subyacente es que se cifra pensando en que **solo el receptor** pueda leer el mensaje. Esta asimetría hace que estos códigos se denominen a veces **asimétricos**, por contraposición a los **simétricos** (clave privada), donde emisor y receptor comparten la misma información.

Queda patente que el diseño de tal protocolo ha de ser muy cuidadoso para evitar un ataque alternativo al esperado que rompa la seguridad del sistema. Toda la seguridad del sistema recae en la función trampa, ese sutil sacrificio de información que hace público un dato (la clave de cifrado) que, teóricamente, permite calcular otro dato (la clave de descifrado) el cual, sin embargo, hay que mantener en secreto.

Las funciones *trampa* (a veces confundidas con *hash*, cuidado: en criptografía moderna **hash** es otra cosa) no son sencillas de encontrar. En los últimos años, cada problema del que se sabe que es un buen candidato se ha probado como base de criptosistemas de clave pública. Hoy existen varias opciones interesantes, casi todas con aritmética modular:

- **Factorización:** dados dos primos grandes (del orden de 2^{512} , unas 155 cifras decimales), p y q , cualquier ordenador multiplica enseguida $p \cdot q = N$. Sin embargo, dado N , hallar p y q no es sencillo. Esta función trampa se utiliza en **RSA**, el método más usado hoy.
- **DLP (Discrete Logarithm Problem):** dado un primo p y un natural $g < p$, hallar $h = g^a \pmod{p}$ para un a cualquiera es sencillo; pero dado h , hallar el exponente a es impracticable (para p grande). Se usa en **Diffie–Hellman** (DHEP) y **ElGamal**, base de **PGP** y **GPG**.
- **Raíces cuadradas módulo n :** dado un entero no primo n y $g \pmod{n}$, es sencillo hallar $x = g^2 \pmod{n}$; pero, dado a , hallar g (su raíz cuadrada módulo n) es impracticable. Base del método de **Rabin**.

Todos estos problemas han sido útiles y lo siguen siendo, pero con las pruebas de los **ordenadores cuánticos** se está comprobando que ciertos problemas considerados **NP** pasan a ser resolubles en tiempo polinomial. La seguridad reside en el tiempo de computación y el coste: es fundamental que no sea rentable para un atacante. Como estos ordenadores (hoy no accesibles al público general) han conseguido reducir considerablemente el tiempo de computación, se ha logrado factorizar números que para un ordenador (o superordenador convencional) llevan muchísimo tiempo de cálculo. El **NIST** ha convocado un concurso para encontrar criptosistemas en una era **postcuántica**.

Cifrado RSA

<https://www.youtube.com/watch?v=CMe0COxZxb0>

En el protocolo RSA no hay ningún dato compartido entre todos los usuarios. Cada uno de ellos, por ejemplo Alice, genera su clave así:

- Escoge dos **primos grandes** p_A , q_A y calcula $N_A = p_A \cdot q_A$.
- Calcula $\varphi(N_A) = (p_A - 1)(q_A - 1)$, donde φ denota la función de **Euler**.
- Escoge un número E_A coprimo con $\varphi(N_A)$.
- Calcula d_A verificando $E_A \cdot d_A \equiv 1 \pmod{\varphi(N_A)}$.

La **clave pública** de Alice es el par (N_A, E_A) . El resto se mantiene **privado**.

Supongamos que Bob quiere enviar un mensaje m a Alice y, sin perder generalidad, que $m < N_A$. Entonces Bob cifra haciendo

$$M = m^{E_A} \pmod{N_A}.$$

Una vez recibido M , Alice descifra haciendo

$$M^{d_A} = (m^{E_A})^{d_A} = m^{E_A d_A} = m^{1+r\varphi(N_A)} \equiv m \pmod{N_A},$$

por el **Teorema de Euler**.

Definición

Sean $K_A = (N_A, E_A)$ y $k_A = d_A$ un par de claves pública y privada, respectivamente, calculadas según el procedimiento anterior. El criptosistema RSA queda definido por

$$C(K_A, m) = m^{E_A} \bmod N_A, \quad D(k_A, M) = M^{d_A} \bmod N_A,$$

donde el conjunto de mensajes en claro es $\mathcal{P} = \mathbb{N}_{<N_A}$, y el de mensajes cifrados es $\mathcal{C} = \mathcal{P}$.

Observación

Los parámetros de seguridad actuales son $N_A \sim 2^{2048}$. Además, la elección de p_A y q_A debe ser cuidadosa para evitar que la factorización de N_A sea factible por métodos específicos (no buenos en general, pero muy eficaces para determinados números). En particular, un error de principiante es escoger p_A y q_A **demasiado próximos**.

Retos actuales

Los criptosistemas actuales peligran con los ordenadores cuánticos, por ello se ha avanzado en técnicas y retos de mayor complejidad que plantear problemas de factorización de números. En este vídeo, Eduardo Sáenz de Cabezón nos explica de forma sencilla el por qué y qué reto afrontamos en la actualidad.

<https://www.youtube.com/watch?v=5kBHBCKoUTQ>